Handout S05: Bảo vệ Khóa Riêng tư: SoftHSMv2, PKCS#11 & Chuyển dịch Hậu Lượng tử (PQC)

Học phần: Cơ sở hạ tầng khóa công khai (ATHK 512) · Lớp CHAT4P
Đơn vị: Khoa An toàn Thông tin — Phân hiệu Học viện Kỹ thuật Mật mã tại TP.HCM
Giảng viên: Nguyễn An Khương (Khoa Khoa học & Kỹ thuật Máy tính, Trường ĐHBK Tp. HCM)
Trợ giảng: Nguyễn Hữu Hoàng Huy

---

1. Cách ly Khóa Riêng tư qua Chuẩn Giao tiếp PKCS#11

Khóa riêng tư của CA không bao giờ được phép xuất hiện dưới dạng văn bản rõ (plaintext) trong bộ nhớ RAM của hệ điều hành:

```
graph TD
    App["Ứng dụng CA (OpenSSL / Step-CA)"]
    API["Giao diện Lập trình Cryptoki (PKCS#11 API)"]
    Driver["Trình điều khiển Module Bảo mật (SoftHSM / Thales / YubiHSM)"]
    Hardware["Phần cứng Bảo mật Cách ly (Secure Element / Cryptographic Boundary)"]

    App -->|Gọi hàm C_Sign, C_GenerateKeyPair| API
    API --> Driver
    Driver --> Hardware

    subgraph SecurityBoundary["RANH GIỚI BẢO MẬT AN TOÀN"]
        Hardware --> KeyStorage["Khóa Riêng tư (Private Key)<br/>Không thể trích xuất ra ngoài!"]
        Hardware --> CryptoEngine["Bộ vi xử lý Mật mã<br/>Thực hiện ký trực tiếp bên trong"]
    end
```

---

2. Mối Đe dọa Lượng tử & Bộ Chuẩn FIPS PQC của NIST (08/2024)

Máy tính lượng tử quy mô lớn ứng dụng thuật toán Shor sẽ giải quyết bài toán logarit rời rạc và phân tích thừa số nguyên trong thời gian đa thức, bẻ gãy hoàn toàn RSA và ECC:

```
graph TD
    Threat["MÁY TÍNH LƯỢNG TỬ (THUẬT TOÁN SHOR)"]

    Threat --> Broken["BỊ BẺ GÃY HOÀN TOÀN<br/>- RSA-2048 / 3072 / 4096<br/>- ECDSA (P-256, P-384

    Threat --> Safe["AN TOÀN KHÁNG LƯỢNG TỬ (NIST CHUẨN HÓA 2024)<br/>Dựa trên bài toán Mạng tinh

    Safe --> FIPS203["NIST FIPS 203: ML-KEM<br/>Cơ chế Đóng gói Khóa (KEM)<br/>Mức an toàn: ML-KE
    Safe --> FIPS204["NIST FIPS 204: ML-DSA<br/>Chữ ký số Mạng tinh thể (RFC 9881)<br/>Mức an toà
    Safe --> FIPS205["NIST FIPS 205: SLH-DSA<br/>Chữ ký số Dựa trên Hàm băm"]
```

---

3. Bắt tay Lai Hậu Lượng tử (Hybrid Key Exchange) trong TLS 1.3

Để bảo đảm tính tương thích và bảo vệ hai lớp (phòng ngừa trường hợp thuật toán PQC mới có lỗ hổng toán học tiềm ẩn), các hệ thống Web PKI tiên tiến áp dụng cơ chế lai:

```
sequenceDiagram
    autonumber
    participant Client as Web Client / Trình duyệt
    participant Server as Web Server (TLS 1.3)

    Note over Client: Sinh khóa tạm thời Cổ điển (X25519)<br/>+ Khóa tạm thời PQC (ML-KEM-768)
    Client->>Server: ClientHello [Key Share: X25519 + ML-KEM-768]
    Note over Server: Đóng gói bí mật chung (KEM Encap)<br/>+ Tính toán trao đổi khóa X25519
    Server-->>Client: ServerHello [Key Share: X25519 + ML-KEM Ciphertext]
    Note over Client,Server: Khóa phiên chung = KDF(Shared_X25519 || Shared_MLKEM)
    Note over Client,Server: Phiên mã hóa bắt đầu (Bảo vệ an toàn trước cả Siêu máy tính và Máy t
```

---

4. Tài liệu Tham khảo Chuẩn Quốc tế

1. **OASIS Standard:** *PKCS #11 Cryptographic Token Interface Base Specification Version 3.0*, 2020.
2. **NIST FIPS 203:** *Module-Lattice-Based Key-Encapsulation Mechanism Standard (ML-KEM)*, 2024. doi.org/10.6028/NIST.FIPS.203
3. **NIST FIPS 204:** *Module-Lattice-Based Digital Signature Standard (ML-DSA)*, 2024. doi.org/10.6028/NIST.FIPS
4. **IETF RFC 9881:** *Use of the ML-DSA Algorithm in Internet X.509 PKI and CRL Profiles*, 2024.